AIC · AI+开源 · 答辩材料

SpringGuard

基于 Open Code Review 的 Spring 智能审查增强

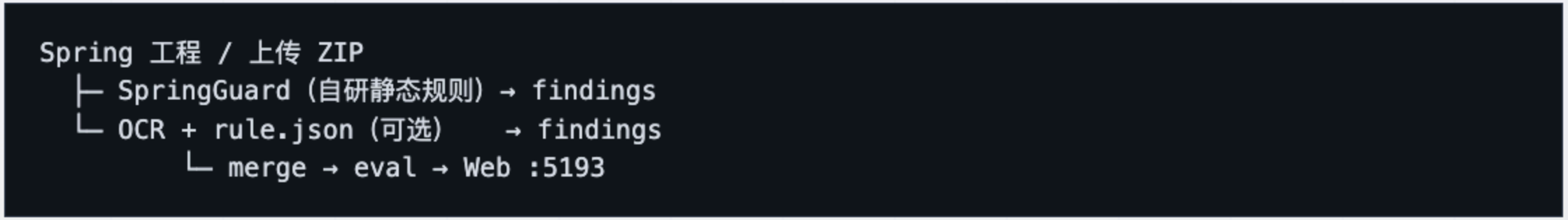
确定性规则 × 可选 AI × 可复现评测

参赛方向：AI 开发工具与开源协作

问题与场景

- 事务自调用失效、缺 `@Valid`、MyBatis `${}` 注入等高发
- 纯大模型：不稳定、难复核；纯人工：成本高
- 目标用户：Java / Spring 学生与中小团队

方案架构


Spring 工程 / 上传 ZIP
├─ SpringGuard（自研静态规则）→ findings
└─ OCR + rule.json（可选） → findings
└─ merge → eval → Web :5193

AI 与开源如何融合

上游

alibaba/open-code-review

Apache-2.0 · **未改源码**

自研增强

规则引擎 · 规则包 · 评测

正/负例 · Web 上传服务

不是薄封装：扩展走官方规则包与进程外编排。

自主实现内容

- `spring_guard.py`：Controller / Service / Mapper 规则
- `app_server.py` + Web：样例扫描 / ZIP 上传 / 评测
- `eval/`：金标准 Recall + 干净样例 Precision
- `spring-buggy` / `spring-clean` 对照样例

可验证效果

1.0	1.0	0
召回率 Recall（6/6）	精确率 Precision（含 clean）	干净样例误报

复现：`python3 eval/run_eval.py`

评测对照

集合 / 模式	结果
spring-buggy + Guard	**TP 6/6 · Recall 1.0**
spring-clean	**0 findings · 无误报**
OCR（本轮长时未完成）	可选增强，演示以 Guard 为主

功能演示要点

- 一键：`./scripts/demo.sh` → http://127.0.0.1:5193/
- 上传 Spring/Java ZIP（≤50MB）或扫描官方样例
- 按「全部 / 严重 / 高 / 中」筛选；右侧看证据代码
- 「跑金标准评测」输出 Recall / Precision

开放成果

- 公开仓库：https://github.com/NEX-coding/springguard
- 代码 · 规则包 · 评测 · 样例 · Web · 文档 · 视频
- 清单披露上游许可与自研边界

后续计划

- 补全 OCR 对比实验；扩大真实负例集
- 更多 Spring 规则（如 `@Async`）
- CI 接入；视情况向上游贡献规则示例

谢谢

SpringGuard

把开源 AI 审查底座，变成可复现的 Spring 工程安全网。

https://github.com/NEX-coding/springguard